資安事件通報與處理 SOP

文件編號：SEC-SOP-003　版本：v1.4　生效日期：2026-05-15　權責單位：資訊安全中心

1. 事件等級與通報時限

等級	範例	通報時限
P1 重大	個資外洩、勒索病毒、正式環境遭入侵	發現後 15 分鐘內
P2 高	員工帳號遭盜用、惡意程式感染單一電腦	發現後 1 小時內
P3 一般	收到釣魚郵件但未點擊、異常登入警示	1 個工作天內

2. 通報管道

資安專線：分機 7110（24 小時）；電子郵件：security@yunqiao.example；夜間與假日請直接撥打資安值班手機 0900-000-711。

3. 帳號遭盜用處理步驟

1. 立即在 IAM 主控台停用該帳號，並撤銷所有登入工作階段與存取權杖（token）。
2. 重設密碼，並要求使用者重新綁定多因素驗證（MFA）。
3. 保留證據：匯出該帳號最近 7 天的登入紀錄；不可刪除可疑郵件或檔案。
4. 於 1 小時內通報資訊安全中心（P2 事件）。
5. 檢查該帳號期間內的權限異動、新增的 API 金鑰與郵件轉寄規則，發現異常一併撤銷。
6. 事件處理完成後 3 個工作天內提交事件報告。

4. 疑似勒索病毒處理步驟

1. 立即拔除網路線或關閉 Wi-Fi，讓電腦離線。
2. 不要關機，也不要重新開機，以保留記憶體中的證據。
3. 拍照記錄螢幕上的勒索訊息。
4. 15 分鐘內撥打資安專線分機 7110 通報（P1 事件）。
5. 等待資安人員到場，期間不要插入任何隨身碟或外接硬碟。

> 禁止事項：不要自行聯絡攻擊者或支付贖金；不要在社群媒體或對外管道討論事件；不要自行刪除可疑檔案。

5. 事後檢討

P1、P2 事件結案後 10 個工作天內召開事後檢討會議，產出根因分析與改善行動，並追蹤到完成。